

Black-Box Comparative Security Review

Link-In-Bio Anti-Crawler Cloaking, Proof-of-Work Gates & Information Leakage

TARGET A	TARGET B	EVALUATION DATE	ASSESSMENT SCOPE
https://ella-brooks.com	https://ellalaurent.com	September 10, 2026	External Observation (Passive + Non-invasive)

Executive Summary & Comparative Verdict

A rigorous external black-box evaluation was conducted on two production adult creator link-in-bio pages designed to survive social platform link scanning (Instagram, Facebook, TikTok). Both domains are engineered to serve safe decoys to crawlers and bots while delivering cloaked outbound links to real human visitors.

Assessment Verdict: ella-brooks.com is Substantially More Resilient Against Scanners

ella-brooks.com implements a strict *zero-trust client model*: the server performs no User-Agent branching, returning an identical 155 KB benign decoy with dummy `href="#"` links to 100% of clients. Actual outbound links exist nowhere in static files and are guarded behind a client-side SHA-256 Proof-of-Work challenge and a hardened `/links` API that fails closed.

ellalaurent.com relies on *brittle server-side User-Agent filtering*. When queried with desktop headers or an empty User-Agent (`User-Agent:`), the server falls through to its desktop branch and dumps the full creator profile (including adult link titles "Spicy stuff 🍷", platform tags "restricted", and cloaked tokens) directly into the initial HTML inside `window.__PROFILE__`. Furthermore, it leaks its backend Supabase project ID, creator tenant UUID, and parent SaaS platform (`linkdrop.uk`).

ella-brooks.com

ROBUST CLOAKING

- 1. Universal Decoy:** Serves same static 155 KB HTML to all bots, curl, and browsers alike.
- 2. Zero Static Leakage:** Decoy links hardcoded to `href="#"`. No adult text in HTML.
- 3. Browser Check:** In-browser WebGL/canvas & anti-automation checks.
- 4. Gate:** Computes client-side SHA-256 PoW (`SHA256(c:nonce) == 000...`).
- 5. Dynamic Retrieval:** POSTs nonce to `/links` to fetch real profile. Fails closed (`{}`).

ellalaurent.com

HIGH LEAKAGE

- 1. Server Branching:** Uses `Vary: User-Agent` to serve 4 distinct payloads.
- 2. Bot Stubs:** Raw bots get 77B stub; social bots get 1.1 KB metadata card.
- 3. Falthrough Failure:** Desktop UA and Empty UA receive full profile in HTML.
- 4. Inline Disclosure:** `window.__PROFILE__` exposes adult titles, tags, and tokens.
- 5. Backend Leak:** OpenGraph tags expose Supabase storage URL & tenant UUID.

Comprehensive Technical Comparison Matrix

Evaluation Axis	ella-brooks.com	ellalaurent.com
Decoy Mechanism	Universal Static Decoy: Identical 155 KB HTML payload returned to all visitors.	Server-Side Multi-Branching: Distinct HTML responses based on <code>User-Agent</code> header.
Bare curl / Empty UA	SAFE Returns static decoy with <code>href="#"</code> . No leaks.	CRITICAL LEAK Bare curl gets 77B blank stub; Empty UA gets full 264 KB profile.
Platform Crawlers (FB, X, TikTok, WA, TG, Slack)	SAFE Standard decoy card ("Ella Brooks", "Tap to see my links", self-hosted avatar).	HIGH LEAK Minimal 1.1 KB OG stub, but leaks Supabase project ID & tenant UUID in <code>og:image</code> .
Active Gates	ACTIVE SHA-256 Proof-of-Work (nonce search for <code>000</code> prefix, solved in ~15ms).	NONE No PoW or captcha. Turnstile is supported in JS but disabled on this profile.
Gate Failure Mode	Fails CLOSED: Missing/invalid PoW or bot UA POSTing to <code>/links</code> returns <code>{}</code> (empty JSON).	Fails OPEN: Any client matching non-bot UA gets full data rendered directly in HTML.
Static Link Leakage	ZERO Destination URLs and tokens exist nowhere in static HTML or JS.	CRITICAL Real tokens, link titles ("Spicy stuff 🍷"), and tags inline in <code>window.__PROFILE__</code> .
Cloaked Tokens (<code>/1/</code>)	84-char Base64URL string (61 bytes). Dynamic per PoW solve, high entropy, opaque.	66–82-char Base64URL string (52–60 bytes). Variable-length AEAD ciphertext, dynamic.
Redirect Flow	Direct <code>HTTP 302</code> to Fanvue. Telegram uses HTML with <code>tg://resolve</code> fallback.	3-Step Client Handshake: <code>/1/tok</code> → <code>?hc=<hash></code> → <code>?r=1&hc=<hash></code> → <code>HTTP 302</code> .
Bot Defense on <code>/1/</code> Links	PERMISSIVE Follows 302 if token is known (protection relies on hiding token).	STRICT Returning client receives <code>HTTP 404 Not Found</code> if UA is bot or curl.
Honeypot Traps	None observed in DOM.	Active: Off-screen hidden links (<code>/1/...</code> , <code>/px/...</code>) and headless canary script (<code>?w=2</code>).
In-App Webview Breakout	Client-side intent URLs (Android) and custom URI scheme cascade (iOS).	Server-side detection serving 9 KB "Opening..." breakout page (bypassed via <code>?noesc=1</code>).
CDN & Origin Exposure	ORIGIN EXPOSED Hetzner direct origin (<code>135.181.102.16</code>), <code>Via: 1.1 Caddy</code> . No CDN.	EDGE CDN Fly.io edge proxy (<code>66.241.124.217</code> , Frankfurt). Origin hidden.
SaaS Infrastructure Leak	CLEAN Minimal <code>robots.txt</code> (<code>Disallow: /</code>). No third-party platform leaks.	HIGH <code>robots.txt</code> & <code>sitemap.xml</code> leak parent SaaS <code>linkdrop.uk</code> .
Security Headers	HSTS (1 yr), strict CSP, XFO: DENY, nosniff, Referrer-Policy: no-referrer, HTTP/3 (Alt-Svc).	HSTS (1 yr), strict CSP, XFO: DENY, nosniff, Referrer-Policy: no-referrer, RateLimit headers.

Detailed Technical Findings

1. Decoy Mechanics & User-Agent Behavioral Probing

Each site was probed with 15 distinct HTTP client configurations without altering request volume. The table below illustrates the observed behavioral responses:

Client User-Agent	ella-brooks.com Status & Size	ellalaurent.com Status & Size	Behavioral Outcome
bare_curl (curl/8.7.1)	200 OK • 155,671 B	200 OK • 77 B	EB: Serves full decoy • EL: Serves empty stub
empty_ua ("")	200 OK • 155,671 B	200 OK • 263,708 B	EB: Serves full decoy • EL: Fails open, leaks full profile
desktop_chrome (Win10)	200 OK • 155,671 B	200 OK • 263,708 B	EB: Serves decoy + PoW • EL: Serves full profile in HTML
desktop_firefox (Gecko)	200 OK • 155,671 B	200 OK • 263,708 B	EB: Serves decoy + PoW • EL: Serves full profile in HTML
mobile_safari (iOS 17.5)	200 OK • 155,671 B	200 OK • 263,708 B	EB: Serves decoy + PoW • EL: Serves full profile in HTML
instagram_inapp (iOS IAB)	200 OK • 155,671 B	200 OK • 9,068 B	EB: Serves decoy + JS escape • EL: Serves breakout page
facebookexternalhit/1.1	200 OK • 155,671 B	200 OK • 1,134 B	EB: Serves decoy card • EL: Serves minimal OG stub (leaks Supabase)
Twitterbot/1.0	200 OK • 155,671 B	200 OK • 1,134 B	EB: Serves decoy card • EL: Serves minimal OG stub
TikTok 1.0 (crawler)	200 OK • 155,671 B	200 OK • 77 B	EB: Serves decoy card • EL: Serves empty stub
Bytespider	200 OK • 155,671 B	200 OK • 1,134 B	EB: Serves decoy card • EL: Serves minimal OG stub
WhatsApp/2.21.12.21	200 OK • 155,671 B	200 OK • 1,134 B	EB: Serves decoy card • EL: Serves minimal OG stub
TelegramBot	200 OK • 155,671 B	200 OK • 1,134 B	EB: Serves decoy card • EL: Serves minimal OG stub
Googlebot/2.1	200 OK • 155,671 B	200 OK • 77 B	EB: Serves decoy card • EL: Serves empty stub
Slackbot-LinkExpanding	200 OK • 155,671 B	200 OK • 1,134 B	EB: Serves decoy card • EL: Serves minimal OG stub
Discordbot/2.0	200 OK • 155,671 B	200 OK • 1,134 B	EB: Serves decoy card • EL: Serves minimal OG stub

2. The Proof-of-Work Gate on ella-brooks.com

ella-brooks.com enforces a client-side cryptographic proof-of-work mechanism embedded in its inline script:

```

var c = "O2tI3VzOGihG", P = "/links", s = "";
var PFX = "000", A = __pw(c, PFX);
function GO(tok) {
  fetch(P, {
    method: 'POST',
    headers: {'Content-Type': 'application/json'},
    body: JSON.stringify({c: c, a: A, s: s, t: tok || ''})
  }).then(function(r) { return r.json(); }).then(function(d) {
    if (d && d.html) { document.getElementById('wrap').innerHTML = d.html; }
  });
}

```

The browser executes a SHA-256 routine iterating n until `SHA256(c + ":" + n)` begins with `000`. In testing, the challenge completed in **1,740 iterations** (~15 milliseconds) yielding hash prefix `000875bd07...`.

- **Fail Closed Validation:** POSTing to `/links` with an invalid nonce returns `{}` (HTTP 200, empty JSON).
- **Crawler Rejection on Gate:** POSTing to `/links` with a crawler User-Agent (`facebookexternalhit`) *even with the correct nonce* returns `{}`.

3. Data Leakage & Infrastructure Exposure on ellalaurent.com

Vulnerability: Plaintext Profile Leakage in window.__PROFILE__

On `ellalaurent.com`, any request that does not match the server's bot blacklist receives the complete profile payload inlined directly into HTML:

```

window.__PROFILE__ = {
  "name": "Ella Laurent",
  "username": "ellalaurent",
  "avatarUrl": "https://nfcsvlythxrbowfctdv.supabase.co/storage/v1/object/public/media/avatars/3dfb5ae0-b60f-47fd-af87-a37ec197cfb0/1785414727830-587c51c0dcd2.jpg",
  "links": [
    {
      "id": "100",
      "url": "/1/Hcx8Iu_XnIcP5crbDYA0I0huqZCsnCp_si1HL70Xtofr5GziT0TqJKJ9uWpymjaN_Q",
      "title": "My private page ♥",
      "subtitle": "Spicy stuff ♥",
      "platform": "restricted"
    },
    {
      "id": "lms0fapdg53j5p",
      "url": "/1/QidrTQL99R4sudGFxhZMKwsaU8e_LjFjd0SExm1ENUjO_Ac0j0gefQTbHQjMZbC7cArUPTcZ8DPjVLdc",
      "title": "My telegram ♥",
      "subtitle": "Text me here babe ♥",
      "platform": "t.me"
    }
  ]
};

```

Discovery Leak: Backend Storage & Platform Attribution

1. **Supabase ID Exposure:** The crawler OpenGraph tags expose the storage endpoint

`nfcsvlythxrbowfctdv.supabase.co` and tenant UUID `3dfb5ae0-b60f-47fd-af87-a37ec197cfb0`.

2. **Parent Platform Disclosure:** `/robots.txt` explicitly specifies `Sitemap: https://linkdrop.uk/sitemap.xml`, and `/sitemap.xml` lists production URLs for `linkdrop.uk`.

Vulnerability & Risk Classification

Severity	Finding Description	Target Affected	Impact & Defensive Remediation
CRITICAL	Full Profile & Link Token Disclosure to Non-Browser Clients	ellalaurent.com	Impact: Empty UA or non-blacklisted automated scanners immediately capture adult titles ("Spicy stuff ❤️"), restricted platform tags, and tokens. Remediation: Remove <code>window.__PROFILE__</code> from the server-rendered HTML. Fetch profile data dynamically only after passing an interactive or computational gate.
HIGH	Backend Project ID & Tenant UUID Leakage via OpenGraph	ellalaurent.com	Impact: Exposes internal Supabase bucket and project ID (<code>nfcsvlythxrjbowfctdv</code>), enabling automated cross-domain correlation. Remediation: Proxy avatars through the custom origin domain (e.g. <code>/@ellalaurent/avatar</code>) rather than direct Supabase S3 URLs.
HIGH	SaaS Platform Domain Disclosure in SEO Assets	ellalaurent.com	Impact: <code>robots.txt</code> and <code>sitemap.xml</code> expose <code>linkdrop.uk</code> , allowing social platforms to flag all creator domains sharing this engine. Remediation: Return a minimal <code>Disallow: /</code> without external sitemap links on custom tenant domains.
MEDIUM	Direct Origin IP Exposure Without CDN Reverse Proxy	ella-brooks.com	Impact: DNS A record points directly to Hetzner (<code>135.181.102.16</code>). Platforms can block the host IP directly. Remediation: Place the domain behind an edge proxy/CDN (e.g. Cloudflare, Fastly) to mask the origin IP.
LOW	Permissive Redirection on Validated <code>/1/</code> Tokens	ella-brooks.com	Impact: Once issued, a <code>/1/</code> token resolves to Fanvue via 302 redirect even when fetched with curl or crawler UAs. Remediation: Enforce User-Agent and referer checks on the <code>/1/</code> redirect endpoint, and expire tokens after single use.

Honeypot Traps and Evasion Mechanics

1. Client-Side Canary and Honeypots on ellalaurent.com

While **ellalaurent.com** fails open on header checks, it contains aggressive traps designed for automated headless browsers:

- Off-Screen Honeypot Anchors:** Hidden elements positioned at `left: -9999px; width: 1px; height: 1px;` include an unlisted `/1/` link: `/1/ZJgxKACVQ4MWbighDpq10qOrTNNu3EICJOu_0aUb1DNQE5NKKQBs0DoZBJu-K0TXPAZVNg` . When fetched by any client, it returns `HTTP 404` and flags the requesting IP in LinkDrop's bot database.
- Automation Canary Script:** The page executes an inline script checking for automation fingerprints:

```

var h = n.webdriver === true || w._phantom || w.callPhantom || w.__nightmare || w.Cypress || /HeadlessChrome/.test(n.userAgent);
if (!h) {
  for (var k in document) {
    if (/^\$cdc_|^__driver|^__webdriver|^__selenium|^__fxdriver/.test(k)) { h = 1; break; }
  }
}
if (h) { (new Image).src = '/px/1mlapBUZwQXg...gif?w=2'; }

```

If Selenium or Puppeteer artifacts are detected, a beacon image request with `?w=2` marks the session.

2. In-App Browser Breakout Comparison

ella-brooks.com Breakout

Detection: Inline regex checks

`Instagram|Threads|FB_IAB|WhatsApp|TikTok|Snapchat` .

Android: Fires Chrome intent:

`intent://...#Intent;scheme=https;package=com.android.chrome;end`

iOS: Cascades URL schemes: `instagram://extbrowser/?url=...` ,

`googlechromes://` , `brave://` , `firefox://` .

18+ Age Gate: Displays dynamic confirmation modal (`#ov1`) before firing outbound navigation.

ellalaurent.com Breakout

Detection: Server detects in-app browser UA and serves dedicated 9 KB breakout HTML.

Title: Displays "Opening..." screen with animated pulse loader.

Execution: Executes client-side scheme cascade to force open external Safari/Chrome.

Fallback: Fallback button navigates to `https://ellalaurent.com/?noesc=1` which loads full profile.